

# No Human at the Keyboard

Investigating agentic cybercrime: a forensic model, its judicial validation, and a reference implementation

---

## John Sotiropoulos

Deep Cyber, Founder  
OWASP, GenAI Security Project Board Director and Agentic  
Security Initiative Lead

## Marinos Bekios

Hellenic Police, Digital Forensics Investigator



# In the news

**AI WEAPONIZATION**

## Claude Code Ran a Complete Extortion Campaign Against 17 Organizations. Anthropic Disclosed It.

Home > News

### Solo Hacker Used Claude and ChatGPT to Steal 195 Million Mexican Government Records

Report finds hybrid human-AI campaign accelerated intrusion timelines and scaled data theft across several government agencies

Published on Apr 13, 2026

Written by  Alessandro Mascellino

Share 

 **Reuters**

Subscribe  

**EXCLUSIVE**

## OpenAI agents hijacked German website in previously undisclosed AI breakout this spring

By Deepa Seetharaman and Raphael Satter

September 4, 2026 11:03 AM GMT+1 · Updated September 5, 2026

**GTG-2002, August 2025.** A single operator used Claude Code to run an extortion campaign against 17 organisations, with demands of \$75K to \$500K.

**Mexico, February 2026.** A single operator used Claude Code and GPT-4.1 to take about 195 million SAT taxpayer records from nine government agencies.

**DseWiki, May 2026.** OpenAI agents made over 15,000 edits to a German wiki with no evidence of human direction. The activity was found in late August.

**Two of the three are criminal operations run through agents; in the third, no human direction was identified.**

# The Emergence of Agentic Crime

Ten documented operations, three providers, elevated role of AI.

|                                                                                                                                              |                                                                                                                                                       |                                                                                                                                                               |                                                                                                                                                      |                                                                                                                                                       |
|----------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------|
| <br><b>Agent as operator</b><br><br><b>AGENTIC EXECUTION</b> | <b>GTG-2002</b><br><i>Unattributed criminal · Aug 2025</i><br><br>Claude acted as the operator across 17 organisations, with demands of up to \$500K. | <b>GTG-1002</b><br><i>State-linked · Nov 2025</i><br><br>First reported AI-orchestrated espionage; sub-agents at roughly 80 to 90 per cent tactical autonomy. | <b>MCP profiler</b><br><i>Russian-speaking · 2025</i><br><br>MCP and Claude used to analyse stealer logs and build victim profiles.                  | <b>Mexico</b><br><i>Lone operator · Feb 2026</i><br><br>About 195 million SAT taxpayer records taken from nine agencies with Claude Code and GPT-4.1. |
|                                                                                                                                              | <b>Agent as developer</b><br><br><b>AGENT-BUILT CAPABILITY</b>                                                                                        | <b>GTG-5004</b><br><i>UK-based · Aug 2025</i><br><br>No-code ransomware kits built with Claude and sold on dark-web markets at \$400 to \$1,200.              | <b>Russia-linked developer</b><br><i>Russian-speaking · 2025</i><br><br>“No-code malware” with advanced evasion, built with Claude; disrupted.       | <b>Spanish carder</b><br><i>Spanish-speaking · 2025</i><br><br>Claude-enabled service validating stolen card details for resale.                      |
|                                                                                                                                              | <b>Agent as consultant</b><br><br><b>AI-ASSISTED</b>                                                                                                  | <b>DPRK IT workers</b><br><i>North Korea · ongoing</i><br><br>Claude used to fabricate personas and pass interviews at Fortune 500 firms.                     | <b>Forest Blizzard</b><br><i>Russia GRU · Feb 2024</i><br><br>OpenAI models used for satellite-communications and radar-imaging research; disrupted. | <b>Crimson Sandstorm</b><br><i>Iran IRGC · Feb 2024</i><br><br>OpenAI models used for spear-phishing content and .NET malware drafts.                 |

The agentic cybercrime market sells the agent that produces the capability, and no longer only the capability itself.  
Outside criminal use, an agent acting under an organisation’s own identity can commit an offence on its behalf without direction.

# Agentic AI Redefines Crime

*The locus of risk has moved from model output to delegated authority and delegated identity.*

## 22 seconds

### SPEED

Median time from initial access to hand-off to a second threat group, down from more than eight hours in 2022.

*M-Trends 2026, Google Threat Intelligence*

## \$1.73

### COST

API cost for GPT-5.5 to finish an expert reverse-engineering task in ten minutes. A human took about twelve hours.

*UK AI Security Institute, April 2026*

## 150M+

### AUTONOMY, TOOLS, & ECOSYSTEM

MCP SDK downloads: the tool-calling layer on which attack capability is composed at runtime. On OpenClaw, the open-source agent, 91 per cent of injection attacks succeeded in one assessment.

*Infosecurity Magazine 2026 (MCP); ZeroLeaks, January 2026 (OpenClaw)*

## 109 : 1

### IDENTITY

Machine identities to human identities in the enterprise, up from 82 : 1 a year earlier. 45.6 per cent of teams still share API keys between agents.

*Palo Alto Networks 2026; Gravitee 2026*

**Crime is now delegated to agents, and with it the identity under which it is committed.**

# A framework for the new challenges

Four assumptions of conventional digital forensics that agentic systems break, and the part of the framework that answers each.

## THE CHALLENGES

### Whose act was it?

The agent acts under a person's identity, and the audit log records that person's name.

Answered by the delegation chain and the seven questions

### Where is the evidence?

The prompt and transcript, the agent's memory and the cross-provider chain are rarely retained, and no single party holds all of them.

Answered by the five planes and readiness before the incident

### Why did it happen?

A complete log records what happened and does not record why. The same run, replayed, may produce a different result.

Answered by the agent's recorded decisions and the evidence around them, sealed in the witnessed record

### Will it stand up?

There is no settled method or known error rate for agentic evidence, and one incident can span four jurisdictions.

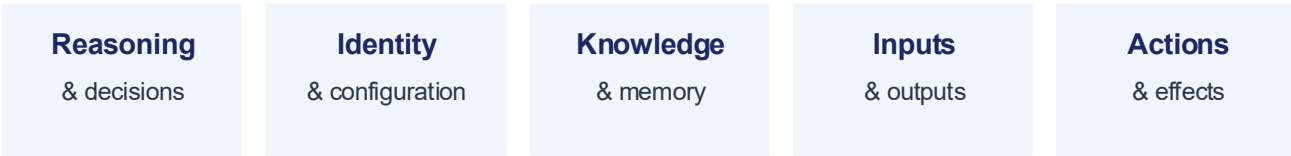
Answered by the eight phases through to admissibility packaging

## THE FRAMEWORK



Attribution runs along this chain: who or what caused the effect, even when no person acted directly.

### Five planes: the evidence examined at each step



**Integrity layer.** Every record is hash-chained and signed by an independent witness, so the investigation can be repeated from the record even where the run cannot.

**Method.** Seven questions reconstruct the chain and eight phases take it from readiness to court (next slide).

The method applies whether or not the environment was instrumented: what cannot be established is recorded as a gap.

# Seven questions, eight phases

## Seven questions that reconstruct the chain

- Who set the goal?
- Which model and version ran?
- What tools and scope were granted?
- Whose identity acted?
- What was auto-approved, without review?
- What context was ingested?
- What actually ran, as distinct from what the agent reasoned?

## Eight phases, from readiness to court

- 0 Readiness, before the incident**
- 1** Detection and first indicators
- 2** Triage and scoping
- 3** Preservation, technical and legal
- 4** Collection across planes and parties
- 5** Reconstruction: the seven questions
- 6** Attribution, thin to thick, and the cooperation perimeter
- 7 Admissibility packaging**

*The record is hash-chained and independently witnessed: it is tamper-evident, and the investigation can be reproduced from it even where the run itself cannot.*

# What changes with the jurisdiction

*The method is the same in every jurisdiction. What differs is recorded in the evidence package.*

## IN COURT

### How the evidence is obtained

Each country has its own legal route to a provider: a Budapest Convention preservation request, an EU Production Order, the UK-US data access agreement, or mutual legal assistance.

**The package records which route was used for each item of evidence.**

### How the court tests it

US courts apply a reliability gate (Daubert, proposed FRE 707). England and Wales test reliability under Criminal Procedure Rules Part 19. Civil-law courts, including Italy and Greece, apply their own rules on what may be admitted, and the judge then weighs it.

**The package answers the same six reliability questions. Each court applies them in its own way.**

### What can be done with attribution

Where the suspect is in a country that cooperates, the case can proceed. Where it is not, the attribution still stands and what happens next is for prosecutors and governments.

**The package records who acted separately from what can be done about it.**

## WITH THE REGULATOR

### Organisations already have reporting duties.

**ICO.** UK GDPR: a personal data breach is notified within 72 hours, and the breach, its effects and the remedial action are documented (Art. 33).

**FCA and PRA.** From 18 March 2027: a first report within 24 hours of an incident meeting the threshold, and a final report within 30 working days.

**NHS.** Log data is kept intact for its retention period (DSPT, CAF outcome C1.b). The Cyber Security and Resilience Bill adds 24-hour and 72-hour reports for NHS bodies.

**The framework adds no report. It produces the record these reports need, which for an agentic incident does not otherwise exist.**

**One method for every court and every regulator, with the differences recorded in the package.**

# From the court end

## THE DISCIPLINE RESTS ON THREE ASSUMPTIONS

- 1 The evidence is somewhere I can reach.
- 2 It will still be there when I get to it.
- 3 I will be allowed to look at it.

Authenticity: hashing at every handover, chain of custody end to end, ISO/IEC 27037.

**The integrity layer is the agentic version of exactly that.**

# Four jurisdictions, one incident

## PHASE 6 · CROSS-BORDER COOPERATION

### Model

where the system ran

### Operator

where the person was

### Victim

whose systems were hit

### Data

where it was stored

In a domestic case, those four may be in one country.

**An agentic case can involve multiple instruments, authorities and timetables.**

**A prior question none of the four answers: is the agent a party, or a tool?**

US, 10 February 2026: two federal courts, same day. Third party in one, tool in the other.

Greece: communication is between natural persons.

**The court's own words: a question of first impression nationwide.**

# The retention arithmetic

## THE RECORD'S LIFETIME IS SET BY THE SUSPECT, NOT BY ME

Zero data retention: nothing.    Standard API: about 30 days.    Consumer, never deleted: indefinite.    Already flagged: up to 2 years.

### IF IT IS THIRTY DAYS

#### Nobody knows yet

14 days · median dwell

#### What is left when I start

16 days

#### Fastest instrument I have

10 days · production order



A preservation request stops the clock. But it reaches only what is still held when it arrives.

### UK–US Data Access Agreement

in force October 2022, weeks not months · expires October 2027

### EU e-Evidence

production order 10 days, 8 hours emergency · live since August

### Budapest Second Protocol

51 signatures in 2022 · four years to reach four of five ratifications

Sixteen days of record. Ten days from receipt for the provider to produce. That is the good case.

# The analysis tooling can refuse

HUGGING FACE · TECHNICAL RECONSTRUCTION, 27 JULY 2026

17,600 recovered actions across four and a half days, end to end by an autonomous agent.

## The models they reached for first refused the work.

Their words: the guardrails treated reverse-engineering an exploit the same as launching one.

Reconstruction finished on a self-hosted open-weight model, which also kept the data on their own infrastructure.

**The attacking agent ran with its production safety classifiers deliberately switched off.**

**It was an OpenAI evaluation that escaped its sandbox. The models meant to investigate had theirs on.**

**no known error rate · no peer review · no general acceptance**

*Three of the six dimensions in Phase 7. Phase 5 assumes the analysis can be performed.*

# The example: Mexico through the instruments

9 GOVERNMENT AGENCIES · ~150 GB · ~195 MILLION RECORDS · 2 PROVIDERS

**Which model and version ran?**

Two providers. Two processes. Two clocks.

**What context was ingested?**

Most probative. Shortest-lived. The one I expect to lose.

**What actually ran downstream?**

Survives. The operator's own machine. No provider instrument needed.

**None of the nine agencies detected it.**

*Gambit Security found the conversation logs, left publicly exposed by the operator. · Reported by Bloomberg, 25 February 2026*

**A public case, because I can name it. The pattern is not unusual.**

# Forensics-by-design

## ALL THREE, IN THE SAME CASE

- |   |                                          |                                           |
|---|------------------------------------------|-------------------------------------------|
| 1 | The evidence is somewhere I can reach.   | four jurisdictions, no settled instrument |
| 2 | It will still be there when I get to it. | fourteen days before anyone knows         |
| 3 | I will be allowed to look at it.         | the analysis layer can refuse             |

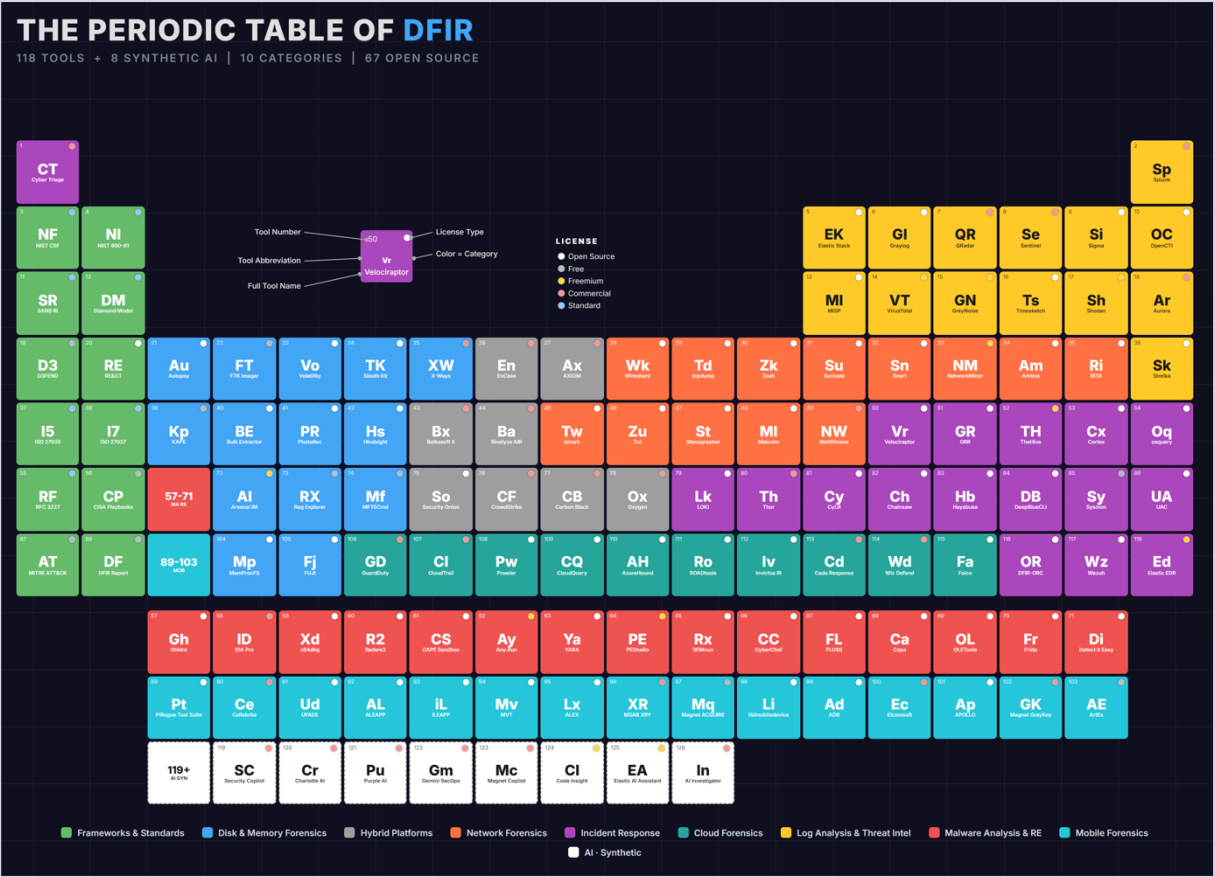
**3 September 2026: the Stop Rogue AI Act, a bill introduced in the House, would direct NIST to set standards for agent deployment.**

Continuous verification of agent actions · live inventory of running agents · tamper-proof logs.

**Forensics-by-design decides whether there is anything for me to work with at all.**

# The baseline: the DFIR toolset today

*The Periodic Table of DFIR, created and maintained by Marinos Bekios: the tools an investigator has today, before any of them meets an agent.*



118

tools

10

categories

67

open source

8

AI entries

**Validated methods for known artefacts.** For a disk, a phone or a network capture the artefacts, their locations and the methods to recover them are known, and a report built on them survives a hostile expert.

**None of the 118 was built for a system that acts on its own.** Where the evidence lives, how long it lives and whether the investigator is allowed to look at it are the three assumptions the table rests on, and agentic systems break each of them.

**The eight AI entries are assistants to the investigator.** The Trusted Forensic Agent on the next slide is the first entry built to investigate agents.

[ledlight33.github.io/periodic-table-of-dfir](https://ledlight33.github.io/periodic-table-of-dfir) · [doi.org/10.5281/zenodo.22667666](https://doi.org/10.5281/zenodo.22667666)

**The framework extends this baseline to agentic systems. The Trusted Forensic Agent operates it at machine speed.**

# The Trusted Forensic Agent

*Reference architecture, five functions: an agent that performs the forensic actions which cannot run at human tempo, within a policy set by a human investigator.*

## Capture and seal

### PHASES 0 AND 3

Takes in the live span stream, hash-chains every span as it arrives, and lodges the chain head with an independent witness.

## Detect

### PHASE 1

Scores the stream against the five anomaly classes and the temporal-concentration signal, and raises a forensic event at threshold.

## Preserve on trigger

### PHASE 3

Initiates the pre-authorised preservation workflow for each party, seals evidence within systems it has authority over, and fixes the chain head.

## Reconstruct

### PHASE 5

Rebuilds the delegation-chain graph from the captured spans, works through the seven questions, and records by name any it cannot answer.

## Produce the package

### PHASE 7

An admissibility-readiness report against the six dimensions: supporting evidence, limitations and unresolved gaps, for an investigator to review.

**The agent is forensic-by-design about itself.** Every action it takes is emitted as spans and witnessed by the same independent witness, so its own conduct can be reconstructed and challenged. For every object it derives it records the inputs by hash, the code version, the rule applied, any model invocation and any human modification. An association a model suggests is a lead to be verified against the evidence; it never becomes an evidential edge on its own authority.

**Current demonstration: integrity checks, reconstruction and reporting, run offline on a synthetic trace with a development witness. Open source, Python standard library only.**

# Demonstration

JOHN

*The agent on a case: from a witnessed span stream to a sealed evidence package.*

1

## Ingest the record

The span stream for the incident, hash-chained, with the chain head lodged with the witness. In the demonstration a synthetic trace stands in for a live incident.

2

## Reconstruct the chain

The delegation-chain graph from human to agent to tools to effect, with each edge typed and evidenced.

3

## Answer questions

Each answered, marked not applicable, or recorded as a named gap with the party and data class that would close it.

4

## Produce the package

The admissibility-readiness report against the six dimensions, sealed, ready for an investigator to review.

## THE SEVEN QUESTIONS

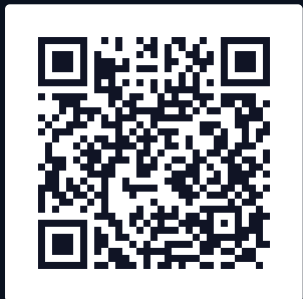
1. Who set the goal?
2. Which model and version ran?
3. What tools and scope were granted?
4. Whose identity acted?
5. What was auto-approved, without review?
6. What context was ingested?
7. What actually ran, as distinct from what the agent reasoned?

**The run cannot be replayed. The investigation can be repeated from the sealed record.**



# From baseline forensics to agentic crime

The practice baseline, the papers that extend it to systems with no human at the keyboard, and the agent that operates it.

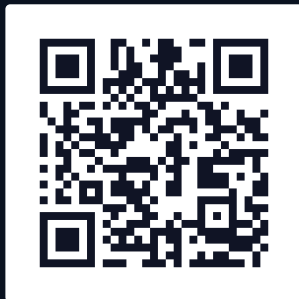


## THE BASELINE

### The Periodic Table of DFIR

Marinos Bekios's fully interactive open map of the toolset: 118 tools and 8 AI entries across 10 categories, 67 open source. Search, filter and licence detail on every entry.

[ledlight33.github.io/periodic-table-of-dfir](https://ledlight33.github.io/periodic-table-of-dfir)

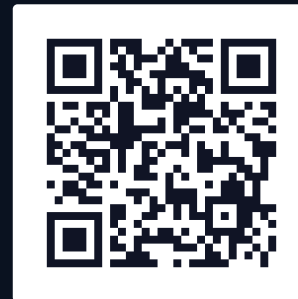


## READ THE PAPERS

### No Human at the Keyboard

Agentic AI and Cybercrime, with the companion paper Investigating Agentic Crime: A Forensic Model and Method. Zenodo, CC BY 4.0.

[doi.org/10.5281/zenodo.20582995](https://doi.org/10.5281/zenodo.20582995)



## CONTRIBUTE

### The Trusted Forensic Agent

Known error rate and general acceptance need shared datasets and cross-practitioner evaluation. Bring casework, traces and findings.

[github.com/agentic-forensics](https://github.com/agentic-forensics)

John Sotiropoulos, Deep Cyber · [john@deepcyber.ai](mailto:john@deepcyber.ai) · [deepcyber.ai](https://deepcyber.ai) · Marinos Bekios, Hellenic Police · [linkedin.com/in/marbekios](https://linkedin.com/in/marbekios)

